

UNIT: 1

❖ What is Information Security (InfoSec)?

Information Security is not only about securing information from unauthorized access. Information Security is basically the practice of preventing unauthorized access, use, disclosure, disruption, modification, inspection, recording, or destruction of information. Information can be a physical or electronic one. Information can be anything like Your details or we can say your profile on social media, your data on your mobile phone, your biometrics, etc. Thus, Information Security spans so many research areas like Cryptography, Mobile Computing, Cyber Forensics, online social media, etc.

During the First World War, a Multi-tier Classification System was developed keeping in mind the sensitivity of the information. With the beginning of the Second World War, formal alignment of the Classification System was done. Alan Turing was the one who successfully decrypted the Enigma Machine which was used by Germans to encrypt warfare data.

Effective information security requires a comprehensive approach that considers all aspects of the information environment, including technology, policies and procedures, and people. It also requires ongoing monitoring, assessment, and adaptation to address emerging threats and vulnerabilities.

❖ Information Security importance

Information security is essential for protecting sensitive and valuable data from unauthorized access, use, disclosure, disruption, modification, or destruction. Here are some of the key reasons why information security is important:

Protecting Confidential Information:

Confidential information, such as personal data, financial records, trade secrets, and intellectual property, must be kept secure to prevent it from falling into the wrong hands. This type of information is valuable and can be used for identity theft, fraud, or other malicious purposes.

Complying with Regulations:

Many industries, such as healthcare, finance, and government, are subject to strict regulations and laws that require them to protect sensitive data. Failure to comply with these regulations can result in legal and financial penalties, as well as damage to the organization's reputation.

Maintaining Business Continuity:

Information security helps ensure that critical business operations can continue in the event of a disaster, such as a cyber-attack or natural disaster. Without proper security measures in

place, an organization's data and systems could be compromised, leading to significant downtime and lost revenue.

Protecting Customer Trust:

Customers expect organizations to keep their data safe and secure. Breaches or data leaks can erode customer trust, leading to a loss of business and damage to the organization's reputation.

Preventing Cyber-attacks:

Cyber-attacks, such as viruses, malware, phishing, and ransomware, are becoming increasingly sophisticated and frequent. Information security helps prevent these attacks and minimizes their impact if they do occur.

Protecting Employee Information:

Organizations also have a responsibility to protect employee data, such as payroll records, health information, and personal details. This information is often targeted by cybercriminals, and its theft can lead to identity theft and financial fraud.

❖ Information Security Components

Information security is necessary to ensure the confidentiality, integrity, and availability of information, whether it is stored digitally or in other forms such as paper documents. Information Security programs are built around 3 objectives, commonly known as CIA - Confidentiality, Integrity, Availability.

- **Confidentiality** - Means information is not disclosed to unauthorized individuals, entities and process. For example, if we say I have a password for my Gmail account but someone saw while I was doing a login into Gmail account. In that case my password has been compromised and Confidentiality has been breached.
- **Integrity** - Means maintaining accuracy and completeness of data. This means data cannot be edited in an unauthorized way. For example if an employee leaves an organisation then in that case data for that employee in all departments like accounts, should be updated to reflect status to JOB LEFT so that data is complete and accurate and in addition to this only authorized person should be allowed to edit employee data.
- **Availability** - Means information must be available when needed. For example, if one needs to access information of a particular employee to check whether employee has outstanding the number of leaves, in that case it requires collaboration from different organizational teams like network operations, development operations, incident response and policy/change management. [Denial of service attack](#) is one of the factors that can hamper the availability of information.

❖ Threats to information System- external and internal thread

What are Internal Cybersecurity Threats?

Internal threats, including potential mistakes by employees, whether due to negligence or by a disgruntled worker, can arise from various sources within an organization, such as [insider security threats](#), misconfigurations, and inadvertent data leaks. Let's identify these potential risks and discuss strategies to safeguard against them, considering their far-reaching consequences and leveraging cyber threat intelligence.

Common Indicators of Internal Threats:

Internal threats can manifest in various forms, and recognizing the early warning signs is crucial. By staying vigilant, organizations can proactively mitigate the risks associated with internal threats. Here are key indicators to watch for:

- **Unusual Employee Behaviour:** Employees exhibiting unexpected or suspicious behaviour may signal internal threats. Security awareness training empowers staff to recognize anomalies, emphasizing the importance of reporting such deviations promptly.
- **Unauthorized Access Attempts:** Unusual login patterns or attempts to access unauthorized areas can indicate potential internal threats. Security-aware employees, through training, become adept at spotting and reporting these access anomalies.
- **Unexplained Changes in Data or Systems:** Alterations to data or system configurations without apparent cause may signify internal threats. Security awareness programs educate employees on being vigilant, prompting them to report any unexplained changes they encounter.
- **Suspicious Activity on Internal Networks:** Monitoring for irregularities in internal network traffic can reveal potential internal threats. Security awareness training equips employees with the knowledge to identify and report suspicious activities occurring within the organization's networks.

What are External Cybersecurity Threats?

Turning our focus outward, we confront the orchestrated challenges posed by external threats. Cybercriminals, state-sponsored actors, hacktivists, and corporate espionage attempts create a formidable force that organizations must guard against. Understand the anatomy of external threats, dissecting their potential impact, and implementing actionable

insights to fortify defenses against these ever-evolving challenges, integrating cyber threat intelligence.

Common Indicators of External Threats:

External threats bring a different set of challenges, often requiring a keen eye to detect. Organizations need to be proactive in identifying these external threats to thwart potential attacks. Here are critical indicators to help recognize and respond to external threats effectively:

- **Frequent, Targeted Phishing Emails:** Security-aware employees are vital in recognizing and reporting frequent, targeted phishing emails. Training programs should focus on enhancing employees' ability to identify phishing attempts and understand the potential risks associated with these external threats.
- **Unexpected Increases in Network Traffic:** Unusual spikes in network traffic from specific locations may signal potential external threats. Security awareness training empowers employees to be vigilant, encouraging them to report any unexpected changes in network activity promptly.
- **Evidence of Malware or Malicious Software:** A workforce educated in security awareness is better equipped to scrutinize evidence of malware or malicious software, especially when originating from external entities. Training programs should emphasize the importance of recognizing and reporting such indicators to thwart potential threats.
- **Unauthorized Access Attempts from External IP Addresses:** Monitoring and reporting unauthorized access attempts from external IP addresses are critical components of defending against external threats. Security awareness training equips employees with the knowledge to identify and respond to suspicious activities originating from external sources.

❖ Security Threat and vulnerability

What is Threat?

A cyber threat is a malicious act that seeks to steal or damage data or discompose the digital network or system. Threats can also be defined as the possibility of a successful cyber attack to get access to the sensitive data of a system unethically. Examples of threats include **computer viruses**, Denial of Service (DoS) attacks, **data breaches**, and even sometimes **dishonest employees**.

What is Vulnerability?

In cybersecurity, a vulnerability is a flaw in a system's design, security procedures, internal controls, etc., that can be exploited by cybercriminals. In some very rare cases, cyber vulnerabilities are created as a result of [cyberattacks](#), not because of network misconfigurations. Even it can be caused if any employee anyhow downloads a virus or a social engineering attack.

Types of Vulnerability

Vulnerabilities could be of many types, based on different criteria, some of them are:

1. **Network-** Network vulnerability is caused when there are some flaws in the network's hardware or software.
2. **Operating system-** When an operating system designer designs an operating system with a policy that grants every program/user to have full access to the computer, it allows [viruses](#) and malware to make changes on behalf of the administrator.
3. **Human-** Users' negligence can cause vulnerabilities in the system.
4. **Process-** Specific process control can also cause vulnerabilities in the system.

❖ Malware & its types

Malware and its Types

Malware is any software intentionally designed to harm, disrupt, or gain unauthorized access to a computer system, network, or data. It is used by attackers to steal sensitive information, spy on users, damage files, or take control of devices without the user's knowledge or permission.

- Short for malicious software used for harmful purposes
- Can steal sensitive data like passwords, banking details
- Spreads through emails, downloads, websites, or USB devices
- Runs secretly in the background without user awareness
- Includes types like viruses, worms, trojans, ransomware, spyware

Types of Malwares

- **Viruses** - A Virus is a malicious executable code attached to another executable file. The virus spreads when an infected file is passed from system to system. [Viruses](#) can be harmless or they can modify or delete data. Opening a file can trigger a virus. Once a program virus is active, it will infect other programs on the computer.
- **Worms** - Worms replicate themselves on the system, attaching themselves to different files and looking for pathways between computers, such as computer network that shares common file storage areas. Worms usually slow down networks. A virus needs a host program to run but worms can run by themselves. After a [worm](#) affects a host, it is able to spread very quickly over the network.
- **Trojan horse** - A [Trojan horse](#) is malware that carries out malicious operations under the appearance of a desired operation such as playing an online game. A Trojan horse varies from a virus because the Trojan binds itself to non-executable files, such as image files, and audio files.
- **Ransomware** - Ransomware grasps a computer system or the data it contains until the victim makes a payment. [Ransomware](#) encrypts data in the computer with a key that is unknown to the user. The user has to pay a ransom (price) to the criminals to retrieve data. Once the amount is paid the victim can resume using his/her system.
- **Adware** - It displays unwanted ads and pop-ups on the computer. It comes along with software downloads and packages. It generates revenue for the software distributor by displaying ads.
- **Spyware** - Its purpose is to steal private information from a computer system for a third party. [Spyware](#) collects information and sends it to the hacker.
- **Logic Bombs** - A logic bomb is a malicious program that uses a trigger to activate the malicious code. The logic bomb remains non-functioning until that trigger event happens. Once triggered, a logic bomb implements a malicious code that causes harm to a computer. Cybersecurity specialists recently discovered logic bombs that attack and destroy the hardware components in a workstation or server including the cooling fans, hard drives, and power supplies. The logic bomb overdrives these devices until they overheat or fail.
- **Rootkits** - A [rootkit](#) modifies the OS to make a backdoor. Attackers then use the backdoor to access the computer distantly. Most rootkits take advantage of software vulnerabilities to modify system files.
- **Backdoors** - A backdoor bypasses the usual authentication used to access a system. The purpose of the backdoor is to grant cyber criminals future access to the system even if the organization fixes the original vulnerability used to attack the system.

- **Keyloggers** - Keylogger records everything the user types on his/her computer system to obtain passwords and other sensitive information and send them to the source of the keylogging program.
 - **Ransomware** - Ransomware is a form of cyber extortion. Its primary goal is financial gain by coercing victims into paying to regain access to their own data.
- I. **Encryption:** The malware uses advanced algorithms to make your files inaccessible.
 - II. **Double Extortion:** Attackers often steal sensitive data *before* encrypting it, threatening to leak it publicly if the ransom is not paid.
 - III. **Human-Operated:** Unlike automated viruses, modern "human-operated" ransomware involves attackers actively navigating your network, escalating privileges, and searching for high-value targets.
- ❖ **Zombies** - a computer, server, or IoT device connected to the internet that has been compromised by malware and is controlled remotely by an attacker, often without the owner's knowledge

❖ Desktop security

Desktop security involves protecting computers from malware, data theft, and unauthorized access through regular updates, strong antivirus protection, and user awareness. Essential practices include enabling firewalls, using complex passwords, encrypting drives, and performing regular backups. Securing the operating system and browsing safely are critical for protecting personal data.

- **Software Updates:** Keep the operating system, browsers, and all applications updated to patch security vulnerabilities.
- **Antivirus/Antimalware:** Use active, updated antivirus software (like [Microsoft Defender](#)) to scan for threats
- **Firewall Protection:** Enable Windows Firewall or third-party firewalls to monitor and block suspicious network traffic.
- **Authentication:** Use strong, unique passwords and enable two-factor authentication (2FA) for accounts.
- **Data Protection:** Regularly back up files to external drives or secure cloud storage. Use encryption (e.g., BitLocker) to protect data from theft.
- **Safe Browsing & Email:** Avoid clicking on suspicious links or attachments. Use secure browsers and consider ad blockers.
- **Physical Security:** Lock your screen (Win + L) when leaving your computer unattended.
- **Manage Permissions:** Use standard user accounts for daily tasks instead of administrator accounts to limit potential damage from malware.